

# HW06 API Testing — Main Report

**Student ID:** 23127379 **Repository:** <https://github.com/AkiraTomori/eshop-sut> **Status:** Completed

## 1. Introduction

This work tests three selected EShop API units: FR-03 password recovery, FR-08 checkout, and FR-15 product update. The objective was to use AI in separate, reviewable technique passes, then apply human audit, gap extension, data-driven execution, and evidence-based defect triage.

The scored scope contains only:

- Pool A: `POST /api/forgot-password` and `POST /api/reset-password`.
- Pool B: `POST /api/checkout`.
- Pool C: `PUT /api/products/:id`.

No GET request was designed or executed as an HW06 test or readiness check. Pool B used Register/Login/Cart POST requests solely to create isolated fixtures; they added no scored cases or assertions. Every retained request inherited `X-Student-Id` from the collection-level `StudentID` environment variable.

## 2. Workflow, tools, and AI declaration

Each Pool followed Generate → Audit → Extend → Execute → Report Bugs, with an exact human confirmation gate after every stage and a separate review of the Pool-local AI audit. AI outputs remained proposals until those gates were confirmed.

Tools actually evidenced in the repository are:

- GPT-5/Codex through the technique-specific HW06 Agent Skills.
- Postman Collection v2.1 artifacts and Newman 6.2.2.
- `newman-reporter-htmlextra` for retained local HTML reports.
- Node.js helper/harness scripts for collection validation and controlled external evidence.
- Docker/local EShop on `127.0.0.1:3000`.
- Restricted SQLite snapshots for state oracles that could not be observed through an allowed endpoint.
- Git and GitHub Actions for history and CI execution.

Postman features actually used

| Feature                             | How it was used                                                                   | Evidence                                       |
|-------------------------------------|-----------------------------------------------------------------------------------|------------------------------------------------|
| Collections/folders                 | One collection per Pool; Pool B separates fixtures from scored Checkout           | Each Pool's collection JSON                    |
| Environment variables               | <code>baseUrl</code> , <code>StudentID</code> , and local runtime fixture values  | Each Pool's environment JSON                   |
| Data variables                      | One confirmed runner row per final case                                           | <code>23127379_FR03/FR08/FR15_data.json</code> |
| Collection-level pre-request script | Validates <code>StudentID</code> , local base URL, and upserts the student header | Collection <code>event</code> scripts          |
| Tests/schema/security assertions    | Status class, documented schema, header, scope, and non-disclosure checks         | Collection scripts and Newman reports          |
| Data-driven Newman                  | Iteration data drives named case IDs and oracles                                  | Local JSON/HTML/CLI evidence                   |
| Workspace/Monitor/Mock server       | Not evidenced                                                                     | Not claimed                                    |

## 3. Pool A — FR-03 Password Recovery

### 3.1 Generate, audit, and extend

Stage 1 produced 79 cases: 36 Domain, 24 State Transition, and 19 Security/Schema. The audit preserved every ID and classified 49 VALID, 12 INVALID, and 18 INCOMPLETE. The invalid group included non-executable wait rows and cases that combined multiple invalid state conditions. Unspecified OTP lifecycle and response contracts remained incomplete rather than receiving invented oracles.

Stage 3 added 13 genuinely missing cases: six allowed password-special-character representatives, leading-zero OTP handling, concurrency/two-user isolation, enumeration, and persistence-focused security checks. Each addition records why the original AI pass missed it.

### 3.2 Execute and report bugs

The approved final set contains 62 IDs. Seven rows remained disabled due documented fixture/contract blockers, so the retained Newman run covers 55 enabled IDs through 62 iterations and 79 POST requests. It produced 266 assertions: 230 passed and 36 failed. At case level, 29 passed and 26 failed.

The 36 assertion failures supported three defect drafts:

1. Four-digit OTPs were issued where six digits are required.
2. Nine invalid new-password representatives were accepted.
3. A redacted persistence check showed plaintext password storage.

The initial double-slash route diagnostic was corrected, overwritten, and excluded as a runner defect. Three redacted Pool A evidence screenshots were generated from the real Newman failure views and restricted persistence snapshot with MSSV **23127379**.

| Metric                                     | Value        | Evidence                               |
|--------------------------------------------|--------------|----------------------------------------|
| AI-generated / audited VALID / human-added | 79 / 49 / 13 | Stage 1–3 proposals                    |
| Final / executed                           | 62 / 55      | Stage 4 data and report                |
| Passed / failed                            | 29 / 26      | Retained Newman JSON by unique case ID |
| Genuine defect root causes                 | 3            | Stage 5 proposal                       |

## 4. Pool B — FR-08 Checkout

### 4.1 Generate, audit, and extend

Stage 1 produced 62 cases: 29 Domain, 8 Decision Table, and 25 Security/Schema. The second-pass human audit classified 35 VALID, 0 INVALID, and 27 INCOMPLETE. The incomplete cases preserve undocumented address, empty-cart, parser, response-schema, replay, and concurrency contracts.

Stage 3 added seven cases for a stale total after cart mutation, nested item/discount injection, query/body pollution, duplicate JSON keys, and a benign apostrophe control. Fixture-only Register/Login/Cart calls created isolated users, JWTs, and known cart totals without adding scored coverage.

### 4.2 Execute and report bugs

All 42 final cases executed. The final collection transmitted 174 local POST requests: 42 scored Checkout calls and 132 fixture calls with zero fixture assertions. Newman reported 209/210 assertions passing and one automated failed case, **FR08-DOM-007**, giving an HTTP/assertion-only case result of 41/1.

That number is not the complete business verdict. Restricted per-case order snapshots prove that 12 additional, non-overlapping cases accepted untrusted client totals rather than the independently calculated authenticated-cart total. Therefore the final requirement verdict is 29 passed and 13 failed. Cart clearing remains unverified because the carts are in memory and there is no permitted non-GET observation endpoint.

The evidence supports two distinct root causes: accepting a JSON array and creating a null-valued order, and trusting client pricing across 12 cases. The corrected **StudentID** mismatch and serialized-regex diagnostic were classified as runner issues.

| Metric                                     | Value       | Evidence                            |
|--------------------------------------------|-------------|-------------------------------------|
| AI-generated / audited VALID / human-added | 62 / 35 / 7 | Stage 1–3 proposals                 |
| Final / executed                           | 42 / 42     | Stage 4 data and full report        |
| Newman-only passed / failed                | 41 / 1      | Newman JSON                         |
| Final evidence verdict passed / failed     | 29 / 13     | Newman plus restricted SQLite state |
| Genuine defect root causes                 | 2           | Stage 5 proposal                    |

## 5. Pool C — FR-15 Update Product

### 5.1 Generate, audit, and extend

Stage 1 produced 86 PUT-only cases: 50 Domain and 36 Security/Schema. The human-revised audit baseline contains 60 VALID, 0 INVALID, and 26 INCOMPLETE. The initial AI audit had proposed 54/1/31; human review restored the missing-path negative partition and separated executable status/state sub-oracles from undocumented schema portions.

Stage 3 added seven cases: a 255-character multi-byte boundary, exponent numeric encoding, an array-valued role claim, duplicate Authorization headers, and field-specific SQL-looking values.

### 5.2 Execute and report bugs

The final suite contains 67 cases. Sixty-five ran in the clean Newman execution and isolated state replay; the concurrency and sequential-replay cases ran through the approved external harness and both passed. The complete case result is 30 passed and 37 failed.

The failures partition exactly into 16 authentication/authorization cases, 18 required-field/type/category validation cases, and three false-success missing-target cases. The first two groups became new High-severity [Issue 72](#) and [Issue 73](#). The last group matches existing [GitHub Issue 52](#), so no duplicate issue was created. The discarded double-slash run did not change the fixture database and was excluded.

| Metric                                     | Value       | Evidence                         |
|--------------------------------------------|-------------|----------------------------------|
| AI-generated / audited VALID / human-added | 86 / 60 / 7 | Stage 1–3 proposals              |
| Final / executed                           | 67 / 67     | Stage 4 main + external evidence |
| Passed / failed                            | 30 / 37     | Stage 4/5 complete verdict       |
| Genuine defect root causes                 | 3           | 2 new Issues + known Issue 52    |

## 6. Cross-pool reconciliation

| Pool/API     | Generated  | Audited<br>VALID | Audit<br>INVALID | Audit<br>INCOMPLETE | Human-<br>added | Final      | Executed   | Passed    | Failed    | Bugs     |
|--------------|------------|------------------|------------------|---------------------|-----------------|------------|------------|-----------|-----------|----------|
| A / FR-03    | 79         | 49               | 12               | 18                  | 13              | 62         | 55         | 29        | 26        | 3        |
| B / FR-08    | 62         | 35               | 0                | 27                  | 7               | 42         | 42         | 29        | 13        | 2        |
| C / FR-15    | 86         | 60               | 0                | 26                  | 7               | 67         | 67         | 30        | 37        | 3        |
| <b>Total</b> | <b>227</b> | <b>144</b>       | <b>12</b>        | <b>71</b>           | <b>27</b>       | <b>171</b> | <b>164</b> | <b>88</b> | <b>76</b> | <b>8</b> |

The final count is **VALID** + **human-added** for each Pool. Pool A's seven disabled final rows explain the 171 final versus 164 executed difference. Pool B's 29/13 final verdict incorporates state evidence and intentionally differs from its 41/1 Newman-

only result. The 159-case CI subset also differs from local final execution because it uses 55/42/62 tracked enabled rows and omits external/fixture-gated rows.

Excel-compatible exports are [test\\_cases/23127379\\_HW06\\_test\\_cases.csv](#) and [test\\_cases/23127379\\_HW06\\_test\\_summary.csv](#).

## 7. CI/CD integration

The push-triggered workflow installs the SUT and pinned Newman, statically validates scope/header/data requirements, materializes reviewed environments from a repository secret, starts [backend/server.js](#), waits on TCP port 3000, runs all three Pool suites, uploads CLI/JUnit evidence, and fails the job if any Newman exit code is non-zero.

A real run exists at [Actions job 98890567631](#), commit [61e0baea](#), artifact [hw06-newman-33183542319-1](#). It executed 159 cases: 96 passed and 63 failed. The screenshot is [reports/CI-fail-sample-2.png](#).

The literal assignment samples are not present. The student declined to manufacture 159/159 by changing the SUT or weakening valid tests and chose the real 96/63 failure as a substitute for the requested 158/159 run. This proves execution and failure propagation but does not satisfy either requested result shape. No instructor exception is present. Full rationale is in [reports/HW06\\_CICD\\_Report.md](#).

## 8. AI-driven API test generator

The repository implements reusable, technique-separated Agent Skills governed by [AGENTS.md](#). The orchestrator limits scope and stage order; Domain, State/Decision, and Security/Schema analyzers produce traceable proposals; the audit/extension stages apply human ownership; builders and reporters consume only confirmed artifacts.

Complete pseudocode is in [test\\_generator\\_design.md](#). The assignment requires the final architecture diagram to be self-drawn by the student, so no AI-generated diagram is supplied. Its path and authorship evidence remain required. The demonstration video is optional and no URL is claimed.

## 9. Bugs and GitHub Issues

The consolidated [bug\\_report.md](#) records eight evidence-backed root causes. Six new HW06 Issues were opened as Issues 68–73, [BUG-PB-002](#) was reconciled into existing Issue 28 with a new HW06 evidence comment, and the missing-product behavior remains linked to Issue 52. Seven redacted screenshots with MSSV [23127379](#) were generated from the real Newman/SQLite views; every URL in the consolidated report was verified after posting.

Runner diagnostics are separated from SUT defects. Pool B's unverified cart-clearing sub-oracle and all unspecified schemas remain evidence gaps rather than passes or failures.

## 10. AI collaboration findings

The three confirmed Pool audit files contain 34 reviewed interactions, consolidated exactly once in [ai\\_audit\\_report.md](#), plus confirmed cross-pipeline records. The confirmed 260-word critique identifies real shortcomings:

- AI-generated state tables admitted non-request waits and mixed invalid conditions.
- First passes collapsed discrete allowed values and missed temporal/parser differentials.
- Generated automation introduced double-slash URLs, a case-sensitive variable mismatch, and an escaped-regex defect.
- Human review corrected artifacts, reset fixtures, reran diagnostics, and separated runner failures from product defects.

The finalizer invocation adds one pending cross-pipeline audit row and does not alter the previously confirmed critique.

## 11. Requirement-to-artifact completeness matrix (HW06 §§6–15)

| HW06 requirement         | Required artifact/evidence           | Source path                              | Status  | User action |
|--------------------------|--------------------------------------|------------------------------------------|---------|-------------|
| §6 — three ≥35 pipelines | Stage 1–5 artifacts and final counts | Three Pool directories; this report §3–6 | PRESENT | None        |

| HW06 requirement                     | Required artifact/evidence                     | Source path                                                                                                | Status                                    | User action                                                                                                    |
|--------------------------------------|------------------------------------------------|------------------------------------------------------------------------------------------------------------|-------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| §6 — human audit and ≥5 additions    | Labels, reasons, additions, “Why AI missed it” | Each Pool Stage 2/3 report                                                                                 | PRESENT                                   | None                                                                                                           |
| §6 — Postman/Newman execution        | Collections, environments, data, HTML reports  | Each Pool <code>postman/</code> directory                                                                  | PRESENT                                   | None                                                                                                           |
| §6 — mandatory student header        | Collection scripts and console screenshot      | Collection JSON; screenshot absent                                                                         | USER ACTION REQUIRED                      | Capture a real console screenshot proving <code>X-Student-Id</code>                                            |
| §6 — bugs on GitHub with screenshots | Markdown reports, issue URLs, screenshots      | <code>bug_report.md</code> ; Issues 28, 52, and 68–73; seven MSSV screenshots generated in posting session | POSTED; IMAGE EXPORTS PROVIDED IN SESSION | Download/retain the generated images in the submission package if file-based screenshot artifacts are required |
| §6 — Postman feature list            | Used features only                             | README and this report §2                                                                                  | PRESENT                                   | None                                                                                                           |
| §6 — two CI samples                  | 159/159 and 158/159 URLs/screenshots           | <code>reports/HW06_CICD_Report.md</code>                                                                   | MISSING BY STUDENT DECISION               | Supply literal runs or written instructor exception                                                            |
| §7 — generator pseudocode            | Student design pseudocode                      | <code>test_generator_design.md</code>                                                                      | PRESENT                                   | None                                                                                                           |
| §7/§11 — self-drawn diagram          | Student-created diagram/authorship evidence    | No file present                                                                                            | USER ACTION REQUIRED                      | Add the student's real diagram and evidence                                                                    |
| §8/§9 — AI declaration/audit         | Tool, time, prompt, output records             | Root and three Pool audit reports                                                                          | PRESENT; finalizer row pending            | Review this finalization row through the confirmation gate                                                     |
| §10 — 200–300-word critique          | Confirmed critique                             | <code>ai_critique.md</code> (260 words)                                                                    | PRESENT                                   | Export PDF for submission                                                                                      |
| §11 — real Newman hostname           | Local hostname evidence                        | Stage 4 reports and retained local reports                                                                 | PRESENT IN MACHINE/REPORT EVIDENCE        | TA may still expect human screenshot context                                                                   |
| §12 — Git commit log                 | Text history with step commits                 | <code>git_commit_log.txt</code>                                                                            | PRESENT                                   | Commit this final package                                                                                      |

| HW06 requirement                  | Required artifact/evidence                   | Source path                                               | Status               | User action                                             |
|-----------------------------------|----------------------------------------------|-----------------------------------------------------------|----------------------|---------------------------------------------------------|
|                                   |                                              |                                                           |                      | only after confirmation                                 |
| §14 — Markdown + PDF reports      | Main report, audit, critique in both formats | Markdown present; PDFs absent                             | USER ACTION REQUIRED | Export and inspect required PDFs                        |
| §14 — public repository           | Public link                                  | README/report                                             | PRESENT              | Verify public accessibility manually                    |
| §14 — Excel cases and summary     | Excel-compatible files                       | <code>test_cases/*.csv</code>                             | PRESENT              | Open in Excel and verify encoding/layout                |
| §14 — CI report/screenshots/links | Canonical report and substitute evidence     | <code>reports/HW06_CICD_Report.md</code> ; one screenshot | PARTIAL              | Resolve literal two-run gap/instructor exception        |
| §14 — README self-assessment      | Four scores and total                        | <code>README.md</code>                                    | PRESENT              | Enter student-owned scores (000–100)                    |
| §14 — final ZIP                   | Correct name and checked contents            | Not created                                               | USER ACTION REQUIRED | Create after all gaps are resolved and inspect manually |
| §15 — assessment table            | Completed student scores                     | README                                                    | USER ACTION REQUIRED | Fill before naming ZIP                                  |

## 12. Conclusion

All three technique-separated API pipelines are complete and human-confirmed. They produced 171 final reviewed cases, executed 164 cases locally, and reached a final evidence verdict of 88 passed and 76 failed across eight defect root causes. The work demonstrates that AI improved coverage breadth and traceability, while human review was necessary to correct invalid cases, missing representatives, runner defects, and evidence interpretation.

The package is not yet submission-ready. The student-drawn diagram, student-header screenshot, saved copies of the generated bug screenshots if required, PDF exports, and final ZIP inspection remain outstanding. GitHub Issue posting/reconciliation is complete. The CI substitution is transparently documented but does not meet the literal two-run requirement without instructor acceptance.

## Appendices

- Appendix A: `ai_audit_report.md`
- Appendix B: `ai_critique.md`
- Appendix C: `git_commit_log.txt`
- Supporting defect summary: `bug_report.md`
- CI/CD reference: `cicd_report.md` and `reports/HW06_CICD_Report.md`
- Generator design: `test_generator_design.md`